Policy 01 — Crime Prevention and Fraud Controls

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually, and on any new product, payment method or significant incident
Relates to	Licensing objective 1 (keeping crime out of gambling) and objective 2 (fair and open gambling); LCCP licence condition 12 (anti-money laundering, see Policy 07) and conditions on cheating and security; Gambling Act 2005 s.42 (cheating)

> Draft for review by a compliance adviser. LCCP references to be confirmed against the current version.

1. Purpose

This policy sets out how PlayStake stops its service being used to commit crime. It covers fraud against customers or against PlayStake, cheating and match-fixing, and misuse of accounts and payments. It also sets out what we do when crime is suspected. Money laundering and terrorist financing are covered in more depth in Policy 07.

2. Our main crime and fraud risks

Risk	Why it matters for PlayStake
Collusion and match-fixing	Customers play each other. Two accounts controlled by the same person or group can fix results, either to launder money (see Policy 07) or to defraud a third party.
Result manipulation	Results decide who gets paid. A forged or tampered result would move money unfairly.
Account takeover	A stolen account could be used to stake or withdraw another person's money.
Multi-accounting	One person running several accounts to collude, evade a self-exclusion or ban, or get round limits.
Payment fraud	Stolen cards used to deposit; chargebacks after playing or withdrawing ("friendly fraud").
Insider misuse	Staff with admin access changing records, approving identities improperly, or moving money.
Ledger error or tampering	Money created or destroyed through a software fault or deliberate change.

3. Controls

3.1 Account security

- **Passwords:**
  - at least 8 characters, with an uppercase letter, a number and a special character
  - hashed with bcrypt (cost 12); never stored or logged in plain text
- **Sign-in protection:**
  - 10 failed attempts in 15 minutes from one address triggers a 30-minute lockout
  - sign-in requests are rate-limited
  - password resets are rate-limited
- **Sessions:**
  - random 256-bit tokens, stored only as hashes
  - cookies are HttpOnly, Secure and SameSite=Lax
  - sessions expire after 7 days, or after 30 minutes without use
  - every session is revoked on a password change or reset
  - closed accounts are signed out everywhere and cannot sign in again
- **Two-factor authentication (TOTP):**
  - available to every customer
  - backup codes are stored hashed
  - codes cannot be replayed
  - setting up 2FA is rate-limited
- **Email verification** is required before identity verification or any withdrawal.
- **Cross-site request forgery:** browser requests that change data are refused if they come from another site.
- **Security headers:** HSTS, X-Content-Type-Options, Referrer-Policy and Permissions-Policy. *Outstanding: Content-Security-Policy and frame-ancestors (Master Manual §8).*

3.2 One person, one account

Customers may hold only one account (Terms of Service). This is enforced as follows:

- **At identity verification:**
  - the platform compares each new submission with every other account
  - a match on the same legal name and date of birth, or an identical identity document image, opens a `SHARED_IDENTITY` case
  - approval of the new account is blocked until the case is resolved
- **Excluded or closed customers:**
  - if the matching account is self-excluded, the exclusion is applied to the new account immediately
  - staff reviewing the case will see if the other account was closed (for example, as under-18 or for fraud)
- **Shared IP addresses:** the AML scan reviews IP addresses used in the last 30 days:
  - accounts that have played each other from the same IP address open a high-severity `SHARED_IP` case

    - four or more accounts on one address open a low-severity case for review
- **Date of birth check:** the date of birth declared at sign-up is checked against the identity document. A mismatch opens a `DOB_MISMATCH` case and blocks approval.

3.3 Match integrity and cheating

Cheating is an offence under s.42 of the Gambling Act 2005. PlayStake prevents and detects it as follows:

- **No self-play.**
    - the database refuses any bet where both players are the same account
    - the lobby and challenge flows refuse it before that point
- **Head-to-head cap.** The same two customers can play each other at most **5 times in any hour**. Repeated head-to-heads are how value is passed between colluding accounts.
- **No PlayStake-run games.** PlayStake's own on-site games (Tic-Tac-Toe and Darts 301) were withdrawn on 25 October 2026. Every match is now a refereed stream match in EA SPORTS FC 27 or Tekken 8. Past game records for the withdrawn games are kept, append-only; no new ones are created.
- **Match Rules and Referee Code of Conduct** (published at `/match-rules`):
    - players must accept the Match Rules before sending or accepting their first stream challenge
    - referees must accept the Referee Code of Conduct when they apply, and before going available or claiming a match
    - the accepted version and time are recorded for each person, so a disputed match is judged against the rules that applied; changing a rule in substance bumps the version and everyone must accept again
    - the rules cover cheating, fixing, bots, staying live, conduct, disconnects, disputes and sanctions; the Code covers independence and conflicts, no betting or gifts, officiating live, deciding only on what the streams show, written notes and confidentiality
- **Results** for every match are decided by an independent human referee:
    - referees apply, are verified (identity and age), and are approved by staff for specific games
    - a referee cannot officiate a match they are playing in, and can hold only one match at a time
    - a referee is never offered, and cannot claim, a match where they follow or are followed by either player, or where either side has blocked the other. The Referee Code of Conduct treats a follow as knowing each other. While a referee is on a match, they and its players cannot start following each other. Each claim records in the audit trail that this check found no link
    - the match can only start while both players are live on Kick with the same game declared, so the referee can watch both feeds
    - every referee action is written to an append-only, hash-chained audit trail that the database protects from edits or deletion; anyone can verify the chain for a match
    - after a decision, either player has 15 minutes to dispute it before payout

    - a match that no referee takes within 10 minutes, or that isn't finished within 2 hours of starting, is cancelled and both stakes are returned in full

- **Disputes.** Any result can be disputed before it pays out (see Policy 02). Staff decisions on disputes are recorded in the audit log.
- **Referee quality.** Overturned referee decisions are tracked per referee. Referees with a high overturn rate are reviewed and can be suspended.
- **Anomaly detection.** A scan every 15 minutes looks for:
    - win rates above 80%
    - winning streaks of more than 10
    - average settlement under 30 seconds
    - hourly volume spikes above 3 times normal

  It alerts staff. For third-party games it can also automatically reduce the game's escrow cap or freeze the developer account that owns it. For PlayStake's own games (EA SPORTS FC 27 and Tekken 8) it only alerts staff, so two colluding players cannot take both games offline. Player-level collusion is handled by the AML scan below.
- **Chip-dumping detection** (Policy 07). The same pair playing 5 or more times in 7 days, with one side winning at least 80% and receiving at least a set amount, opens a `CHIP_DUMPING` case.

3.4 Payments

- Identity and age must be verified before any deposit or withdrawal.
- **Deposits:**
    - between £5 and £1,000 per transaction
    - at most 5 deposit attempts an hour from one address
    - also limited by the customer's own deposit limits
- **Withdrawals:**
    - rate-limited
    - blocked while the account is suspended
    - held for review when an AML case is open, when the amount is large, or when money is going straight back out with little play (Policy 07)
- **Idempotency.** Every money movement uses an idempotency key, so a retried request can never pay twice.
- **Stripe webhooks** are verified by signature and de-duplicated.
- **Chargebacks.** A card dispute on a deposit immediately suspends the account and opens a high-severity `CHARGEBACK` case.
- **Outstanding (Master Manual §8):**
    - Stripe live mode with Radar fraud rules and 3-D Secure
    - GBP currency
    - matching the payout account holder's name to the verified legal name

3.5 The ledger

- **Double-entry.** All money moves through a double-entry ledger. Exactly one function is allowed to change balances. It always writes a debit and a matching credit that sum to zero, and it refuses to take any player or escrow account below zero.
- **Escrow per match.** Each match has its own escrow account, which must net to zero when the match is settled or cancelled.
- **Nightly audit.** Every night at 03:00 UTC, an automatic audit checks:
    - every account balance against its entries
    - every transaction for balance
    - that the system as a whole conserves money

  A failure alerts the compliance inbox and the error-monitoring service at the highest severity, for same-day investigation.

3.6 Staff and insider risk

Admin access is restricted as follows:

- **Access.** Admin tools are limited to the ADMIN role, checked on every request, and require two-factor authentication in production.
- **Audit trail.** Every privileged action is recorded in the append-only admin audit log, with the member of staff, time, IP address, what changed and the reason given.
- **Reasons required.** Staff must give a reason for every account-status, role and KYC change.
- **Rules staff cannot override.** The platform enforces these regardless of role:
    - staff cannot change their own role
    - staff cannot mark an identity as verified unless an approved identity document shows the customer is 18 or over
    - staff cannot lift or shorten a self-exclusion
    - staff can only lower a customer's deposit limit, never raise it
    - staff cannot reopen an account closed as under-18
- **Pre-employment checks.** Before being given admin access, staff complete [DBS / criminal record check and reference checks — to be confirmed].
- **Leavers.** Admin access is removed on the day a person leaves.

3.7 Software supply chain

- Every change is linted, type-checked and tested in CI before release.
- A malware scan runs on every push and weekly, following a 2026 supply-chain incident.
- Errors in production are reported to an error-monitoring service (Sentry).

4. When crime is suspected

1. **Contain.**

    - Suspend the account (`/admin/users`, with a reason). This stops deposits, stakes and withdrawals while still letting the customer sign in.
    - Unsettled matches can be voided with both stakes refunded where needed.
2. **Record.** Open or use an AML case (`/admin/aml`), and record the evidence and every decision on it.
3. **Decide.** The MLRO decides whether to:
    - make a Suspicious Activity Report (Policy 07)
    - report to the police or Action Fraud
    - notify the Gambling Commission as a key event
4. **Don't tip off.** Customers are not told that a report has been considered or made.
5. **Put it right.** Refund innocent third parties. Close accounts involved in fraud or cheating, and forfeit winnings obtained by cheating where the Terms allow.
6. **Learn.** Review the controls and update this policy.

5. Review

The Head of Compliance reviews this policy every year and after any significant incident. Any change to the controls described here requires an update to this document.

Version	Date	Change
0.1	30 September 2026	First draft